



Shai-Hulud

Un ver géant dans mon node_modules !



Arthur MURILLO Dev@**Onepoint**

08/08/2026

onepoint.

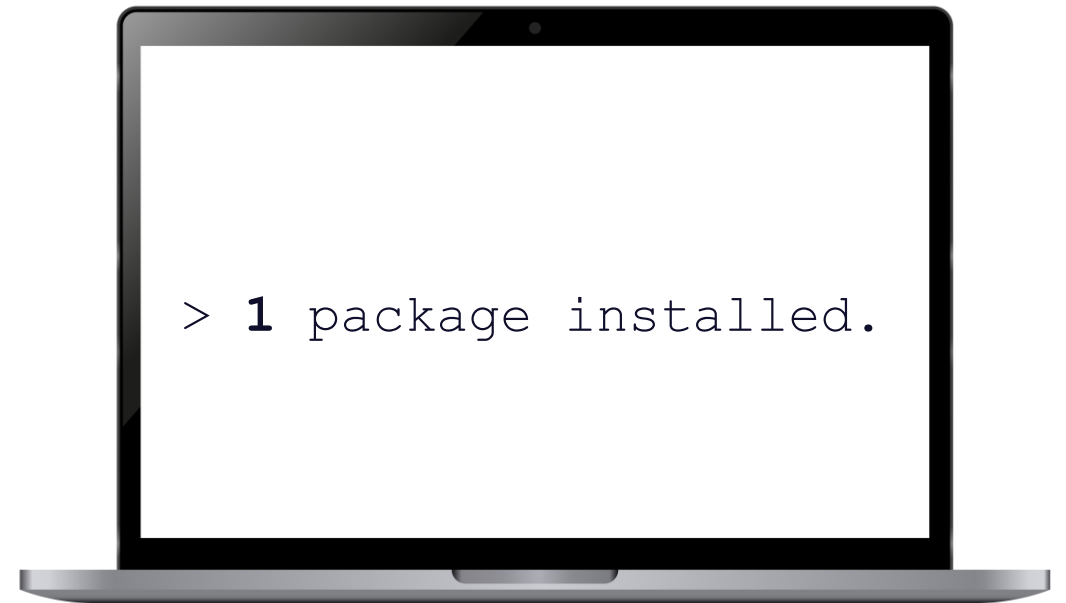


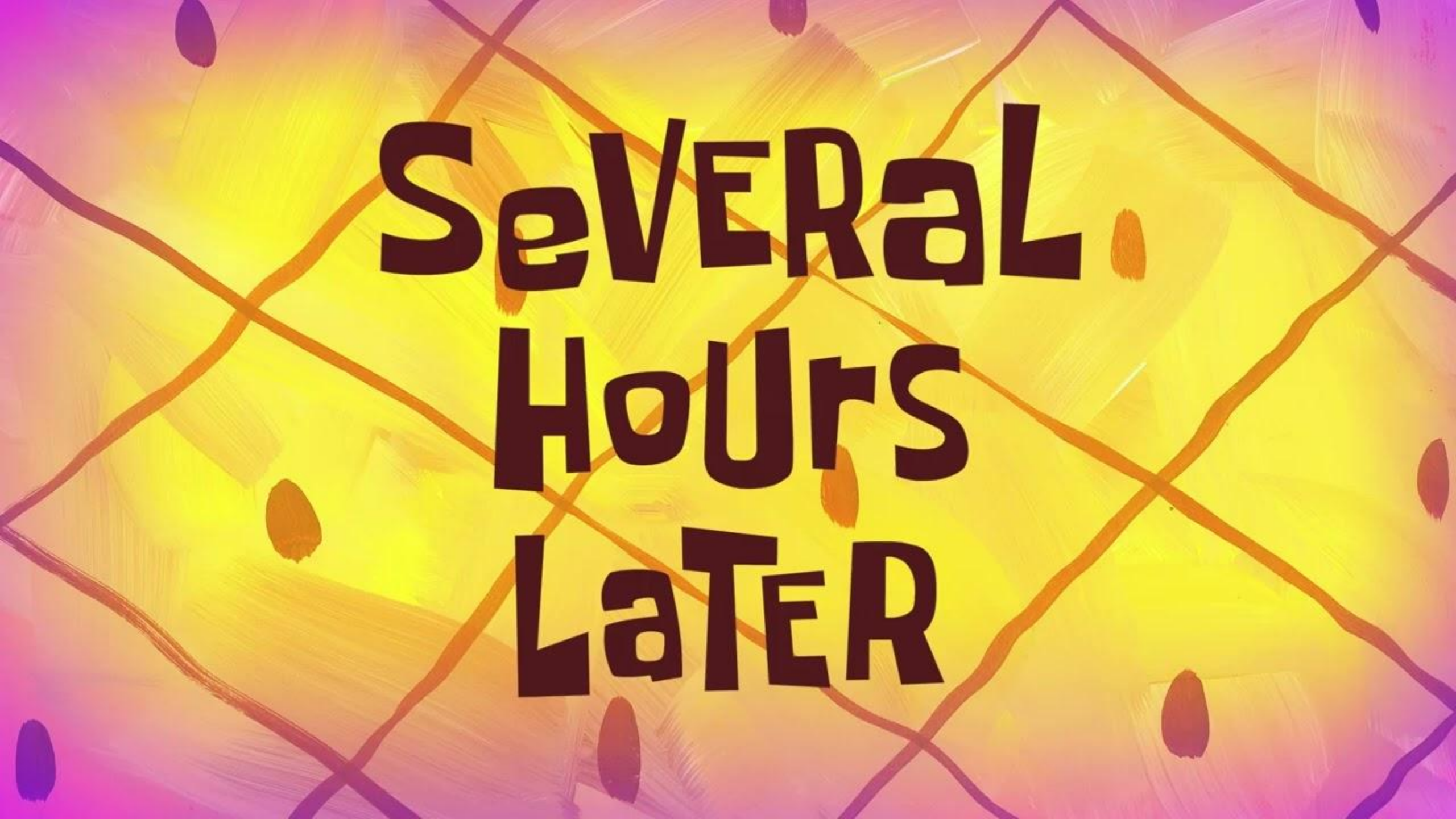


*Angular c'est dépassé, la
bonne pratique c'est
[framework sorti hier]*









**SeVERal
HOURS
LaTER**





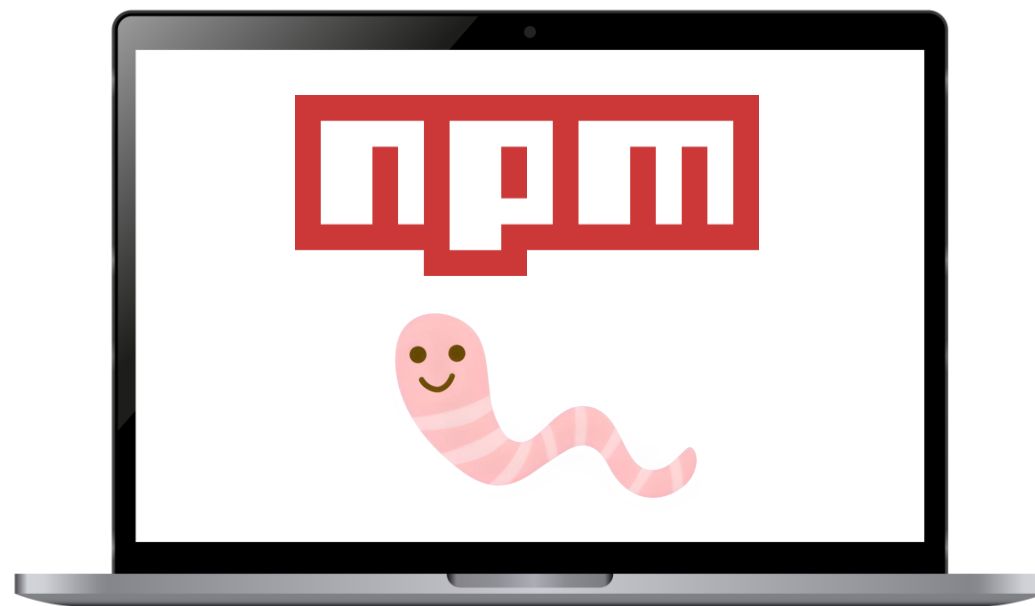
wtf

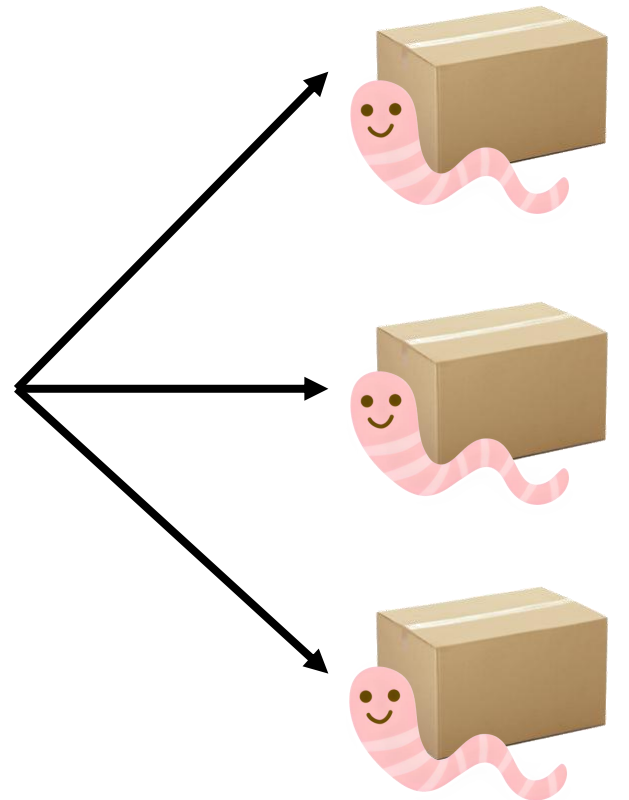


N'utilise pas
« !important » dans ton
css, c'est mal











Oups





UNIT 42TM

BY PALO ALTO NETWORKS

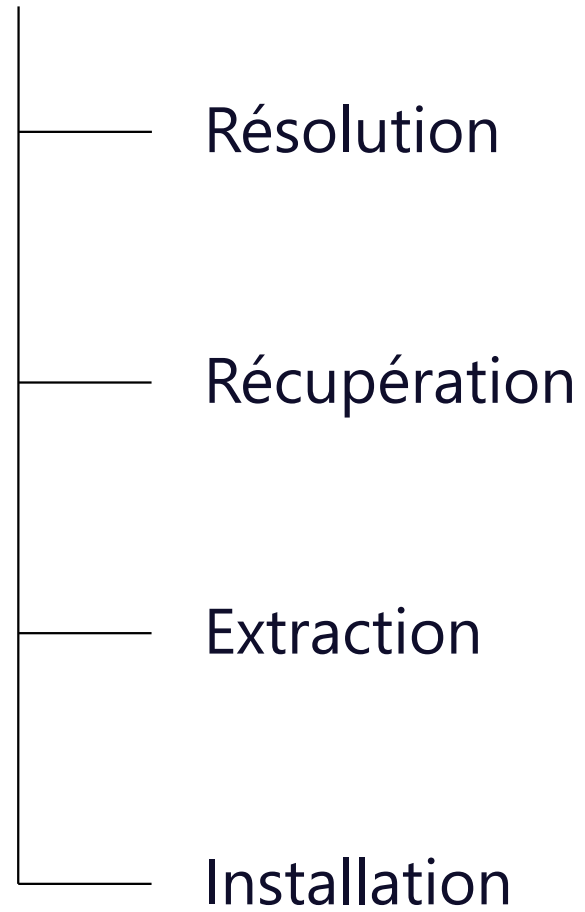


Supply chain

Utiliser les **dépendances** d'un projet comme vecteur **d'attaque**

```
npm install
```


npm **install**



npm **install**



Résolution

Récupération

Extraction

Installation



hoist ~ verb [hɔɪst]

to lift something heavy, sometimes using ropes or a machine



path-to-regexp 

8.4.2 • [Public](#)

mon_app

└─ node_modules/

└─ express/

└─ node_modules/

└─ path-to-regexp/

mon_app

└─ node_modules/

└─ express/

└─ path-to-regexp/

```
const regexp = require('path-to-regexp');
```



mon_app

└─ node_modules/

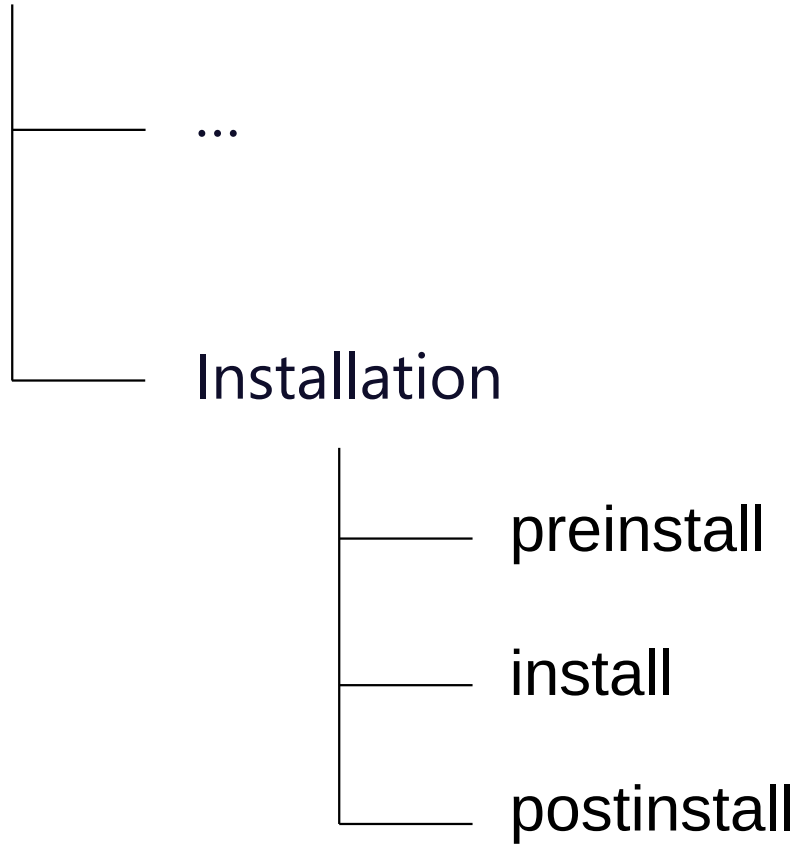


(

└─ express/
└─ path-to-regexp/
└─ .../



npm **install**



```
{  
  "name": "path-to-regexp",  
  "scripts": {  
    "preinstall": "./scripts/pre.sh",  
    "install": "node-gyp rebuild",  
    "postinstall": "./scripts/post.sh"  
  }  
}
```

pnpm



mon_app

└─ node_modules/

└─ express/

└─ path-to-regexp/

mon_app/

└─ node_modules/

└─ express/

└─ .pnpm/

└─ express@4.18.2/

└─ node_modules/

└─ express

└─ path-to-regexp/

└─ path-to-regexp@6.2.1/

└─ node_modules/

└─ path-to-regexp/

→ Liens symboliques

→ Liens systèmes

~/.local/share/pnpm/store/...

~/ .local/share/pnpm/store/

└─ v3/

└─ files/

└─ 1a/e3f2b8c...

└─ 4c/a91d03...

└─ ff/8b2e71...



mon_app/

└─ node_modules/



(

└─ express/

└─ .pnpm/

└─ express@4.18.2/

└─ path-to-regexp@6.2.1/





WARN - The following dependencies have scripts that were not run during installation:

esbuild (has a postinstall script that was ignored)

minimumReleaseAge: 1440

```
pnpm install path-to-regexp
```

ERR_PNPM_NO_MATURE_MATCHING_VERSION

Version *X.Y.Z* (released 10 minutes ago) of *path-to-regexp* **does not meet** the `minimumReleaseAge` constraint

```
pnpm patch path-to-regexp
```



Et ton machin la, c'est
compliqué de migrer
dessus ?

**C'EST L'HEURE
DE LA DÉMO !!**



imgflip.com

**C'EST MOI QUI
DOIT FAIRE LA DÉMO**





Ouais, mais sur un plus
gros projet ?



2 applications conséquentes **en prod**

1500 dépendances

750+ tests unitaires

1 jour ½ de migration sur pnpm

Recherche de documentation

Installation sur les projets

Rédaction d'un retour d'expérience

Adaptations suite au changement de structure du `node_modules`

Intégration dans le pipeline CI/CD

Déploiement sur l'infrastructure cible

Tests exploratoires



npm c'est
dépassé, la
bonne pratique
maintenant c'est
pnpm



Ouais mais et
si tu utilises
....

Et si je n'ai **pas** envie d'utiliser une **alternative** ?

Quand tu attends que ta MR soit relue



npm **audit**

```
[+] no known vulnerabilities found  
Packages audited : ...
```

audited 3090 packages in 21.506s
found **133** vulnerabilities (27 **moderate**, 74 **high**, 32 **critical**)

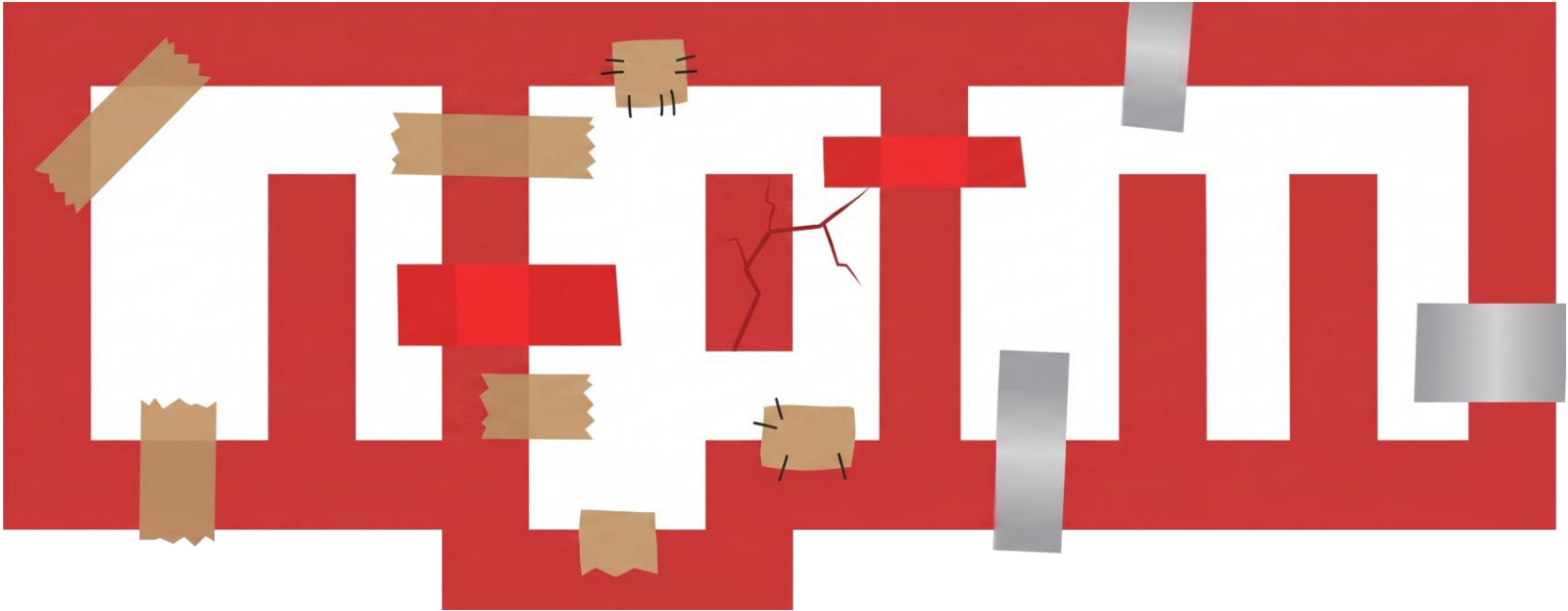
npm **ci**

NPM 11.10.0 adds `min-release-age`

May 21, 2026 · 1 min · [Brandon Pugh](#) | [Suggest Changes](#)

After Years of Supply Chain Attacks, npm Is Finally Closing the Door on Auto-Scripts

 Jun 11, 2026 •  MaK Ulac  4 - 7 min read



				
<i>Scripts bloqués par défaut</i>	 (v12+)			
<i>Dépendances fantômes</i>			 (Par défaut)	
<i>Isolation des dépendances</i>			 (Par défaut)	
<i>Délai de maturité avant installation</i>	 (v11.10+)		 (v4.10+)	 (v10.16+)

M. Murillo, je ne me sens pas très bien...



Shift **left**



मेरी !



openfeedback,



SOURCES

Attaque de la supply chain : *le ver « Shai-Hulud » frappe l'écosystème npm*

<https://unit42.paloaltonetworks.com/fr/npm-supply-chain-attack>

pnpm face à Shai-Hulud : repenser la sécurité des dépendances applicatives

<https://www.sqli.com/fr-fr/insights/pnpm-securite-dependances-npm-supply-chain>

pnpm : *Fast, disk space efficient package manager*

<https://pnpm.io/>

Illustrations : *Google Gemini (Nano Banana v2)*

<https://gemini.google.com>